API Security Risk Analysis Report

Name: Kareem Badran

Internship: Future Interns

Task: API Security Risk Analysis

1. Introduction

This report presents a security analysis of public APIs using Postman. The goal is to identify potential risks related to authentication, data exposure, input validation, and rate limiting while following safe and read-only testing practices.

2. Tools Used

- Postman
- JSONPlaceholder API
- ReqRes API

3. Methodology

The APIs were tested using Postman through read-only requests.

Multiple endpoints were analyzed to observe authentication requirements, response data, error handling, and headers.

Testing focused on:

- Authentication and authorization behavior

- Data exposure to API responses

- Input validation handling

- Presence of rate limiting controls

4. Findings

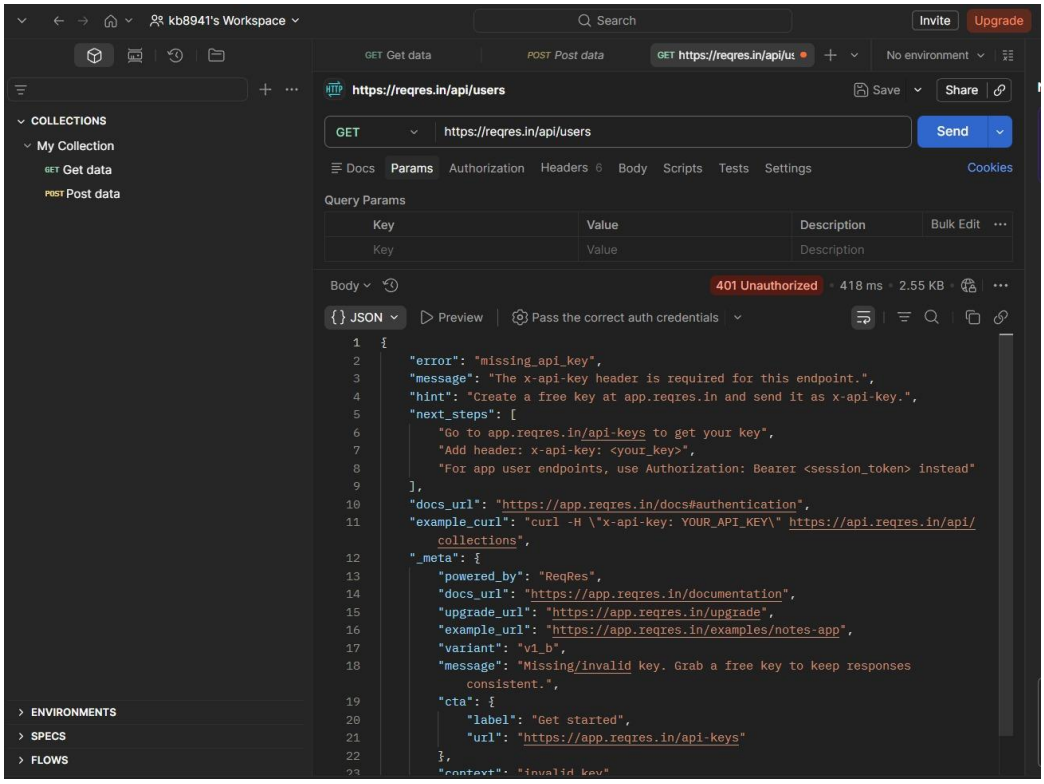
4.1 Lack of Authentication

Risk Level: Medium

The ReqRes API requires an API key for access. When no key is provided, the server returns a 401 Unauthorized response.

Impact: While authentication exists, detailed responses may help attackers understand how the system works.

Recommendation: Limit detailed error messages.



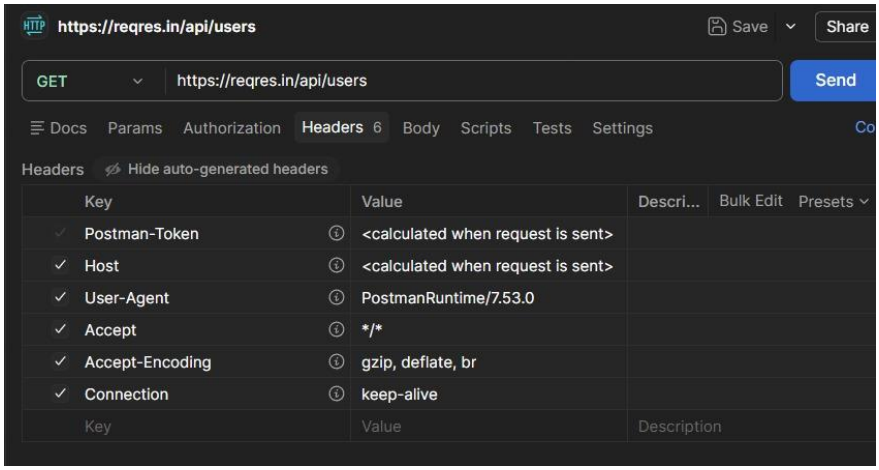
4.2 Information Disclosure Error Messages

Risk Level: Low

The API exposes internal guidance such as how to obtain an API key and required headers.

Impact: This may assist attackers in understanding authentication mechanisms.

Recommendation: Use generic error messages.



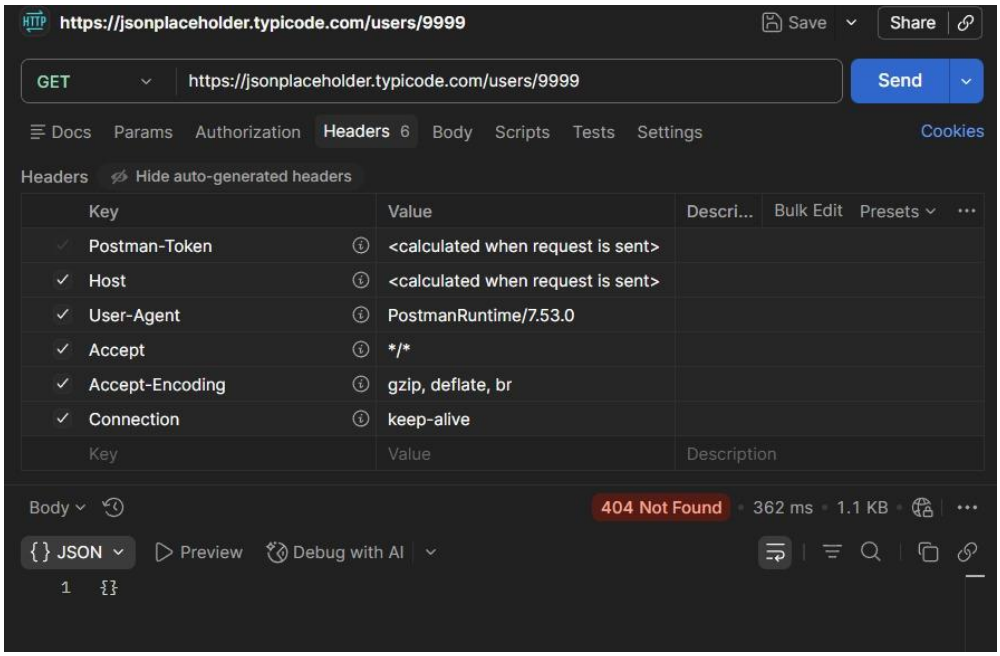
4.3 Input Validation Behavior

Risk Level: Low

Invalid requests return 404 Not Found with an empty response.

Impact: No major risk, but limited feedback.

Recommendation: Provide structured error messages.



4.4 Missing Rate Limiting Indicators

Risk Level: Medium

No rate limiting headers such as X-Rate Limit or Retry-After were observed in the responses, suggesting a lack of request control mechanisms.

Impact: Could allow abuse or excessive requests.

Recommendation: Implement rate limiting controls.

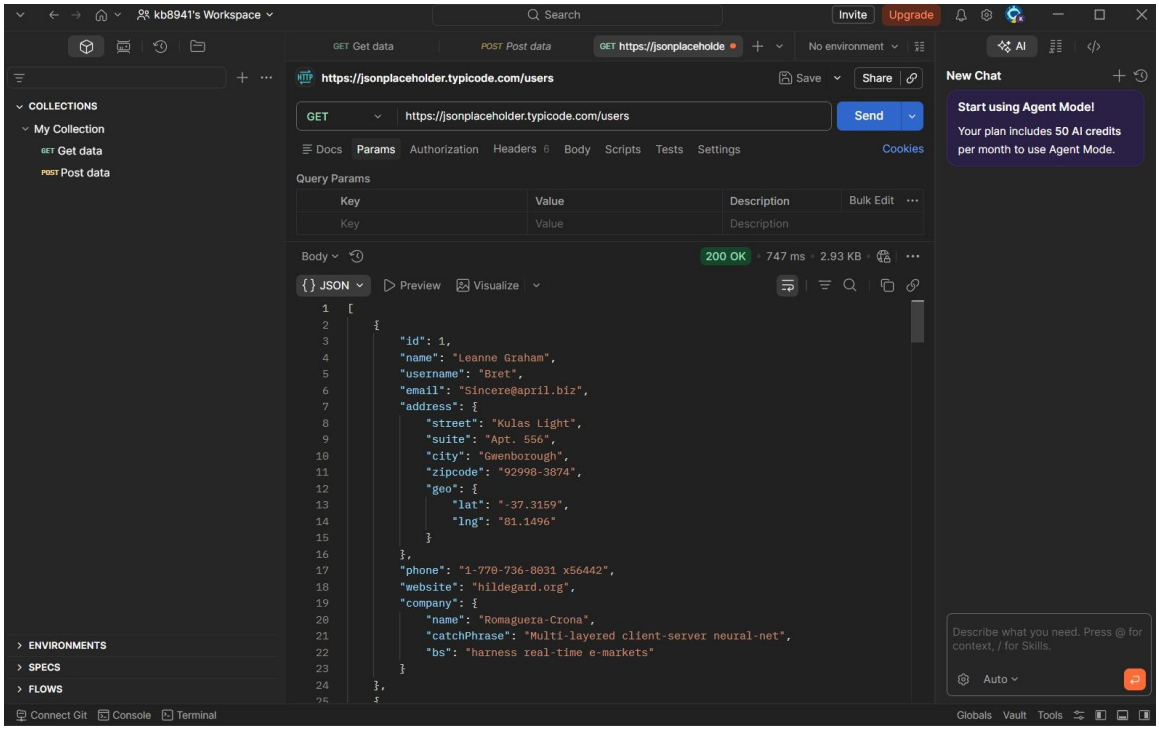
4.5 Excessive Data Exposure

Risk Level: Medium

The API exposes detailed user data including email, phone, and address.

Impact: Increases risk of data misuse and social engineering.

Recommendation: Limit returned data.



5. Conclusion

The analysis identified several common API security concerns including data exposure, lack of rate limiting, and verbose error messages. Proper controls and minimal data exposure are recommended to improve API security.